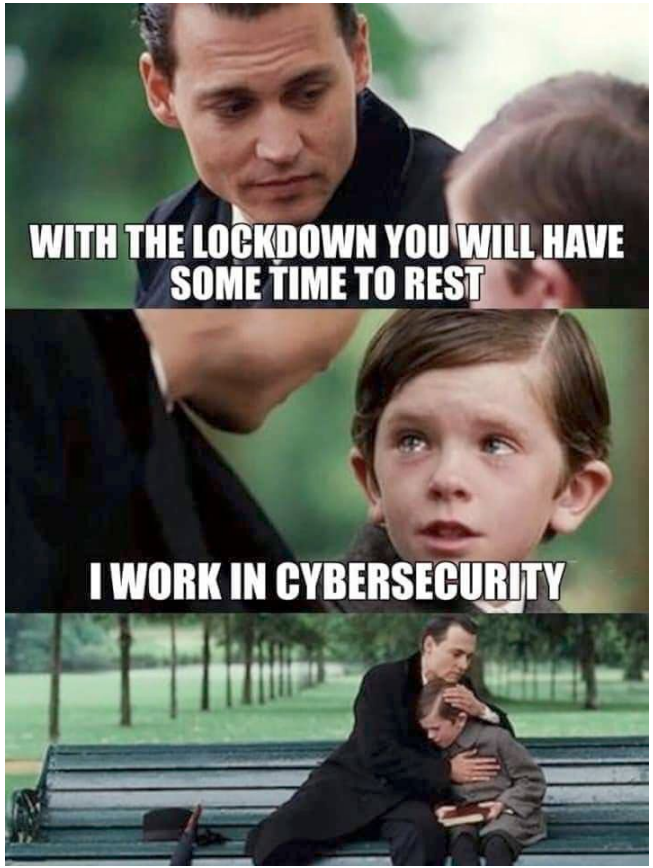
Web Security

Kameswari Chebrolu

Department of CSE, IIT Bombay



https://blog.internxt.com/cybersecurity-meme/

Outline

- What is Computer security?
- What is Web security?
  - Why is it important?
  - Why is it hard?
- What does all this mean to me?

What is Computer Security?

*"**Computer Security** is the process of preventing and detecting unauthorized use of your computer. It involves the process of safeguarding against intruders from using your computer resources for malicious intents or for their own gains "*

(From www.cert.org)

Terms from Definition

- Resource
- Unauthorized use
- Intruders/Attackers
- Safeguard/Defense

Resources

- Computer could be replaced by laptops, desktops, cellphones, medical devices, ATMs, cars etc
- Resources(**Digital assets)** have value
  - CPU
  - Disk Space
  - Network Connection
  - Data: Passwords, Contact List, Credit Card #s, Secret Files, Trade/Military secrets
  - Entire System or Network

Unauthorized Use

- Steal Identity/Information
  - Credit card, social security numbers, Intellectual property
- Cause Inconvenience
  - Reboots, pop-ups, corrupt files
- Disruption of service
  - Launch denial-of-service (DOS) attacks; deface website
- Warfare (spying, sabotage)

Terms from Definition

- ~~Resource~~
- ~~Un-authorized use~~
- Intruders/Attackers
- Safeguard/Defense

Intruder/Attacker Profile

- Can be anyone: insider, outsider, vendor, service-provider etc
- Assumed very powerful
  - Has access to large computational power
  - Can intercept and modify messages
  - Can buy people off
  - Knows implementation details

Incentives for Attacks

- Glory/Bragging Rights
- Malice
- Competition
- **Money (bug bounty/Ransomware/Black Market)**
- Political/ Private Activism (e.g. stuxnet worm , Anonymous Group,)

Upto $20k per bug

Underground Economy

Service	Price
Hack a normal website	$9.99
Hack a high profile site	$9.99 +
Govt. Database of Names, addresses, Phone etc	$20 per 1KB
Fresh emails for spam	$10 per 1MB
http://xxx.yyy.mil full site admin control	$499
http://www.xxx.edu full site admin control	$88
Zero day against iOS	$500,000
50,000 botnets for rent for two weeks	$4000
DDOS for one week/hour	$150/$10

- Several companies specialize in finding and selling exploits
  - ReVuln, Vupen, Netragard, Exodus Intelligence
  - The average flaw sells for $35 - 160K
- Nation/State buyers
  - Israel, Britain, Russia, India and Brazil are some of the biggest spenders

Terms from Definition

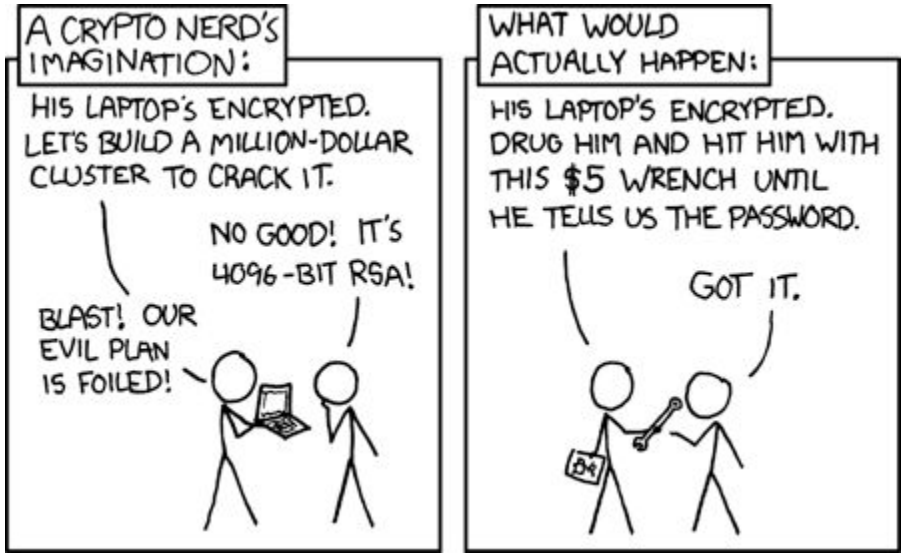
- ~~Resource~~
- ~~Un-authorized use~~
- ~~Intruders/Attackers~~
- Safeguard/Defense

Safeguards/Defense

- Individually, Organization level
- At organization level, security achieved via a “policy”
  - What **action** **principals** can take on an **object**
  - E.g. Only Bob can access the website
  - E.g. Only Bob may view the contents of a webpage
- Security mechanism: method or component to enforce a policy
  - E.g. Authentication via Login page
  - E.g. Encryption to hide message content (https)

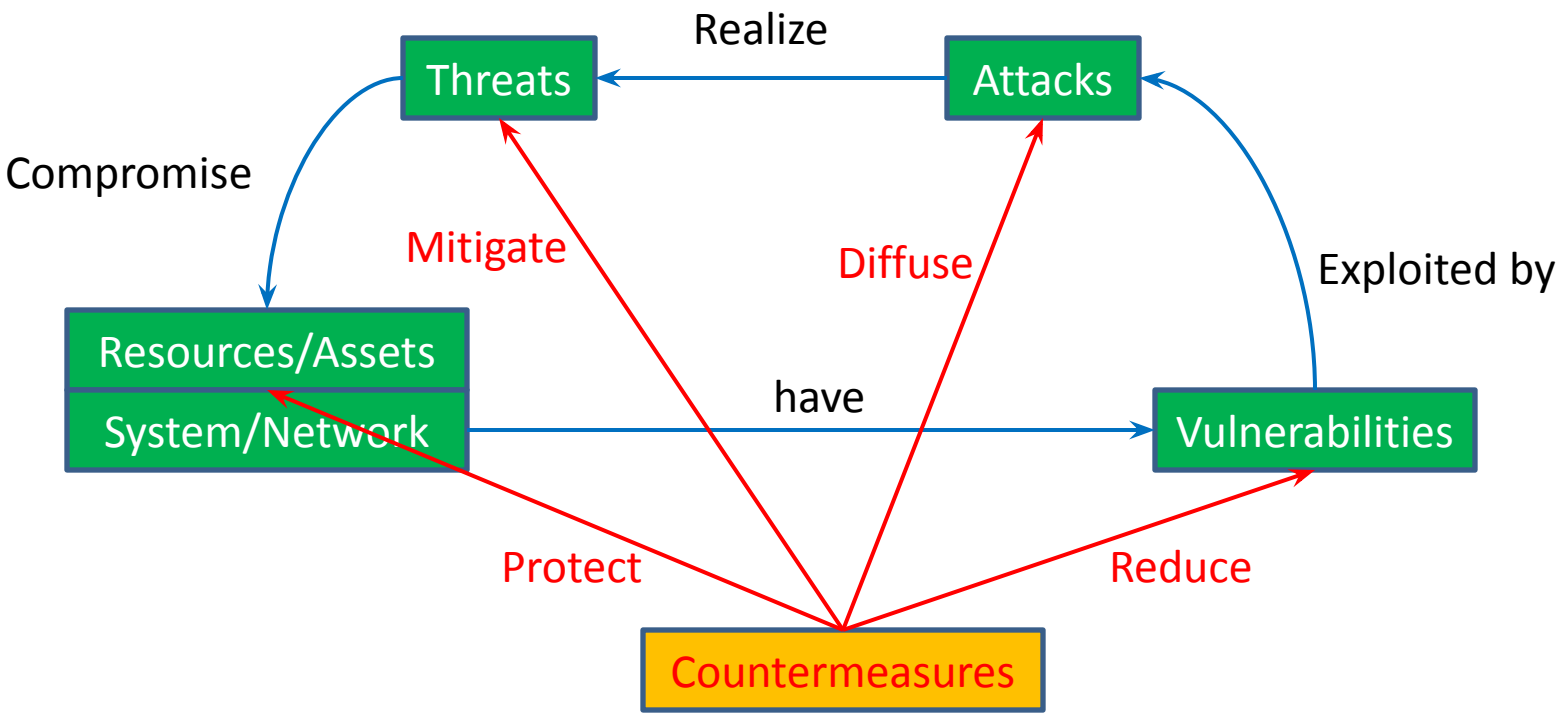
- Many techniques, protocols, products, companies
  - Encryption algorithms, Digital signatures, Hashes, CSRF tokens, Input sanitization etc
  - HTTPs, HTTP header options
  - Anti-virus, firewalls, IDS, Vulnerability scanners
  - Consultancy, Pen-testing companies (threat detection, risk assessment, management etc)

- “If you think technology can solve your security problems, then you don’t understand the problems and you don’t understand the technology.”-- *Bruce Schneier*



https://xkcd.com/538

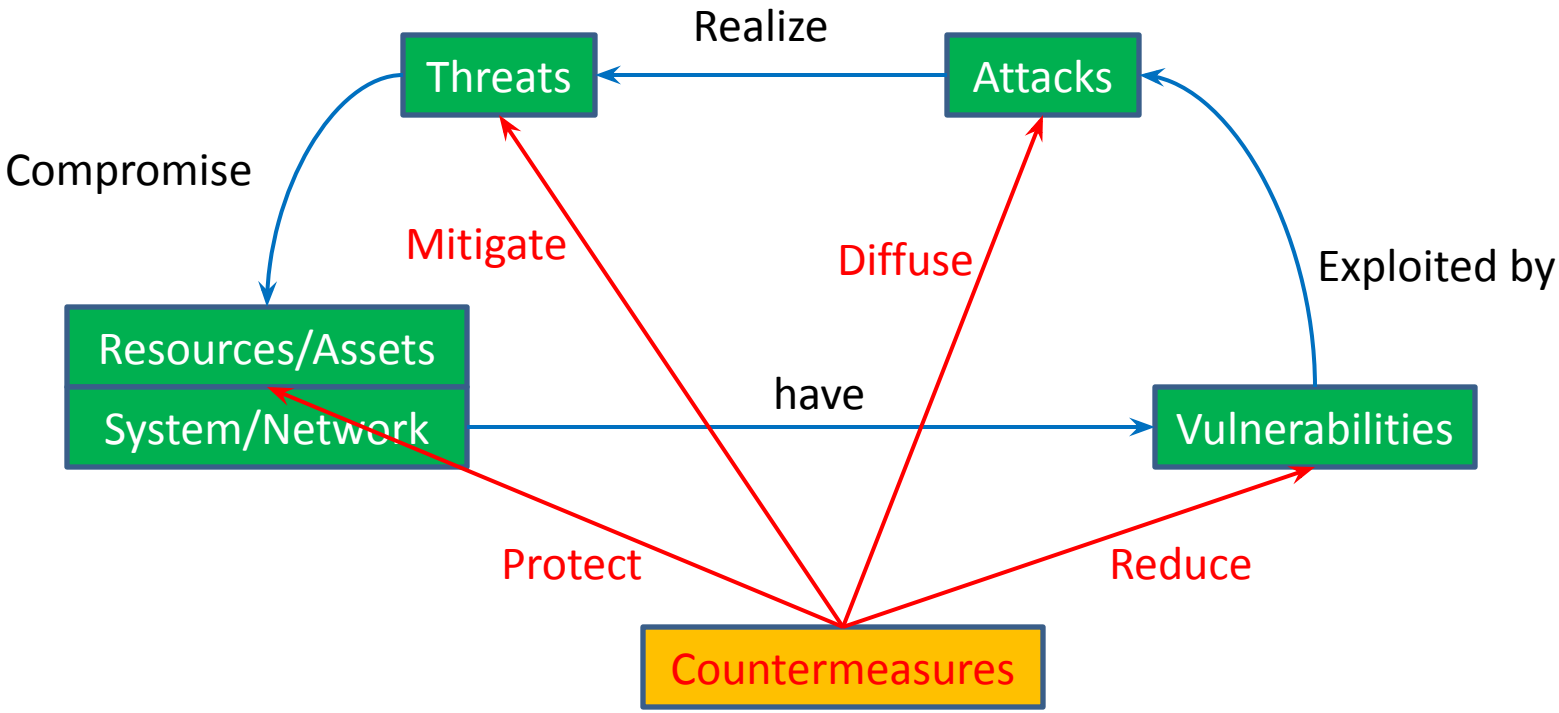
Behold the Security Arena!



Example

- Asset: Webpage
- System: Hosted on a web server
- Threat: Deface the webpage
- Attack: SQL injection + Crack Password
- Vulnerability: Application software (improper data validation); improper password storage
- Countermeasures: Validate input, Least privilege, Strong authentication

Behold the Security Arena!



Tussle between Defenders and Attackers

Outline

- ~~What is Computer security?~~
- What is Web security?
  - Why is it important?
  - Why is it hard?
- What does all this mean to me?

Web Security

- Replace computer with website/web-application!
- Encompasses measures and practices designed to protect websites/web-applications
- **Goal: CIA**
  - **Confidentiality (C), Integrity (I), and Availability(A)** of data and services hosted on the web

- **Confidentiality:** information/resource is not made available or disclosed to unauthorized individuals, entities, or processes
- Example: Online shopping
  - Credit card info not available to third parties

- **Integrity:**
  - Information not improperly modified
  - System performs intended function
- Example: Online Purchase
  - Change price of item from Rs 5000 to Rs 1

- **Availability**
  - Information/resource accessible to authorized users
- Example: Online Purchase
  - Bring the web server down; deny service to other shoppers

Why is Web Security Important?

CoWIN Data leak! Aadhaar, PAN Card info, shared on Covid vaccination portal, made public by Telegram: Report

3 min read • 12 Jun 2023, 05:17 PM IST

Join us

Livemint

Personal information of Indian citizens, including Aadhaar and PAN card details, are reportedly available on Telegram due to a data breach caused by the CoWIN portal

CoWIN data leak: Screenshot of leaked details of Congress leader P Chidambaram by Telegram bot **(Saket Gokhale)**

GOVERNMENT

5 AIIMS Servers Hacked, 1.3 TB Data Encrypted in Recent Cyberattack, Govt Tells RS

Media reports citing investigators had earlier revealed that records of nearly 3-4 crore patients, including high-profile politicians, were compromised.

AIIMS, Delhi. Photo: PTI

16 Dec 2022

Air India claims 4.5 million passengers affected by February data breach

SITA, which serves the Star Alliance of airlines including Singapore Airlines, Lufthansa and United, had in March said it had faced a "highly sophisticated" cyber-attack after which it initiated containment measures.

By: **REUTERS** | Updated on: **Aug 21 2022, 17:33 IST**

Follow us

Share via:

“There are only two types of companies: those that have been hacked, and those that will be.” -- Robert Mueller, FBI Director, 2012

Can lead to significant revenue loss and reputation damage!

- Web security crucial to
  - Safeguard customer data, Prevent Intellectual Property theft (C)
  - Protect the integrity of transactions (I)
  - Business Continuity and Productivity (A)
  - Many industries are subject to regulatory/compliance requirements to meet CIA

- Check out: http://www.informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/

Outline

- ~~What is Computer security?~~
- ~~What is Web security?~~
  - ~~Why is it important?~~
  - Why is it hard?
- What does all this mean to me?

Why is Web Security Hard?

- Tough and dynamic landscape
  - Complex web technologies, diverse ecosystem, rapid development cycles etc
  - Cat and Mouse game
    - Need continuous learning and adaptation
  - Defender: Find/Eliminate all vulnerabilities
  - Attacker: Find only one vulnerability
  - "A good attack is one that the engineers never thought of." -- *Bruce Schneier*

- Ease of attacks
  - Automation
    - Many automated tools to scan websites and launch attacks
    - No major skills needed
      - Malware as a Service, Ransomware as Service, Phishing as a Service etc :-)
  - Cheap
    - Plenty things sold cheap in blackmarket!
  - Distributed and Anonymous
    - Internet supports anonymity and distributed attacks easily

- Usability vs Security
  - More focus on usability and performance
  - Security mechanisms often viewed as nuisance

- Human Factors:
  - Human errors, both in development and use
    - Misconfigurations, poor coding practices, and lack of security awareness !
  - “The user’s going to pick dancing pigs over security every time.” – Bruce Schneier

- Submit password details at fake look-alike site in response to email (**Phising**)
- Download malware app that boasts new features (whatsapp gold **malware; trojans**)
- Trust pop-up ads that warn of computer infection and buy fake and potentially dangerous anti-virus protection (**scareware**)
- The list goes on……

Dear Wells Fargo customer

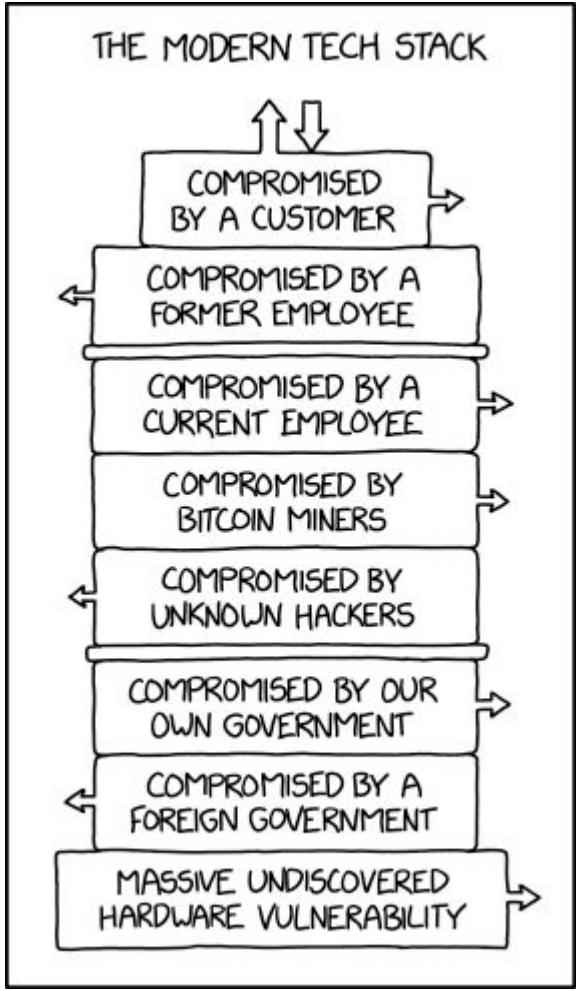
We regret to inform you that your Wells Fargo account could be suspended if you don't re-update your account information. To resolve this problems please click here and re-enter your account information. If your problems could not be resolved your account will be suspended for a period of 72 hours, after this period your account will be terminated.

For the User Agreement, Section 9, we may immediately issue a warning, temporarily suspend, indefinitely suspend or terminate your membership and refuse to provide our services to you if we believe that your actions may cause financial loss or legal liability for you, our users or us. We may also take these actions if we are unable to verify or authenticate any information you provide to us.

Due to the suspension of this account, please be advised you are prohibited from using Wells Fargo in any way. This includes the registering of a new account. Please note that this suspension does not relieve you of your agreed-upon obligation to pay any fees you may owe to Wells Fargo.

Regards, Safe harbor Department Wells Fargo, Inc
The Wells Fargo team.
This is an automatic message. Please do not reply.

(Interesting capitalization here. Why not capitalize Harbor and Team? Because this is a phishing scheme!)



https://www.explainxkcd.com/wiki/index.php/2166:_Stack

Takeaway

"The only truly secure system is one that is powered off, cast in a block of concrete and sealed in a lead-lined room with armed guards - and even then I have my doubts." -- Gene Spafford

- Perfect Security is impossible
- Tradeoff security with other goals (Usability/Cost)
- High level goal: Risk management not complete protection

Outline

- ~~What is Computer and network security?~~
- ~~Why is security important?~~
- ~~Why is security hard?~~
- What does all this mean to me?

What does all this mean to me?

- Protect thyself: Know security best practices to protect your data/system when using web
- Ethical hacking (help the community)
- Help in research: Evaluate vulnerabilities and design new techniques, protocols etc
- Jobs: Help industry safeguard their assets
  - Plenty jobs in web development; add security to resume $\longrightarrow$ solid portfolio!

Goals of the Course

1. Understand Web background
2. Appreciate the challenges posed by Web Security
3. Understand common exploits and how to defend/avoid them
4. In the process, explore/familiarize with a few popular standards/protocols
5. Implement/experiment the ideas (in the form of labs)

“"The value of education is not the learning of many facts but the training of the mind to think." – Einstein???

Summary

- Definition of Computer/Web security
- Security Arena
  - Acquainted with some terminology
- Why Web Security is hard/important?
- What will you get out of this course